INTERNATIONAL CYBERSECURITY AND DIGITAL FORENSICS ACADEMY

Social Engineering & Phishing Campaign Simulation for GRC Professionals

RABIATU UMAR AHMAD

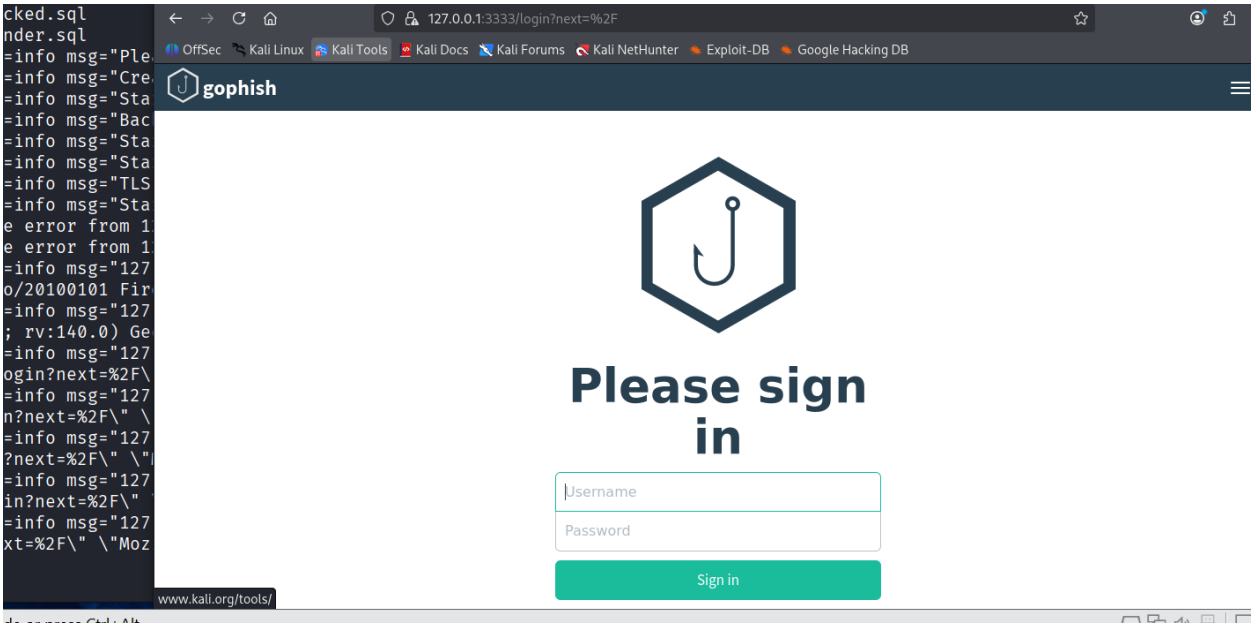
C11/26/CGRCE/17569

COHORT 11

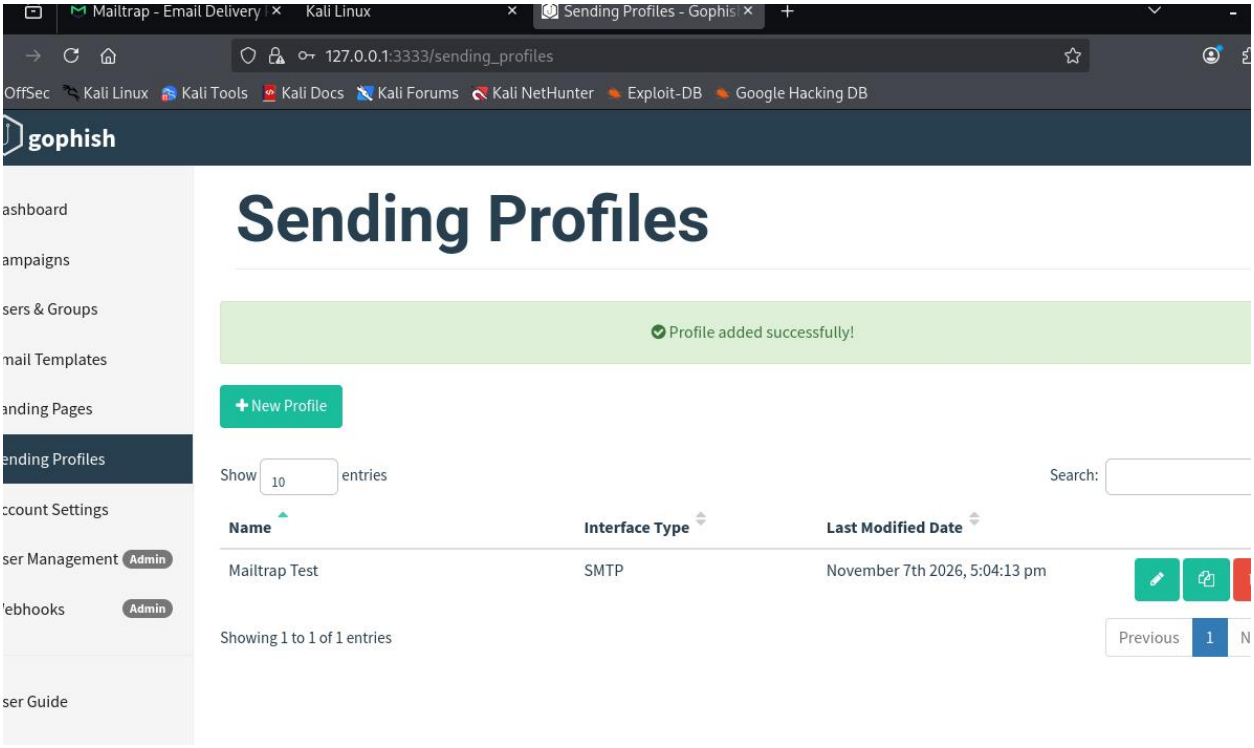
8th November, 2026

Phase 1: Setup and Preparation

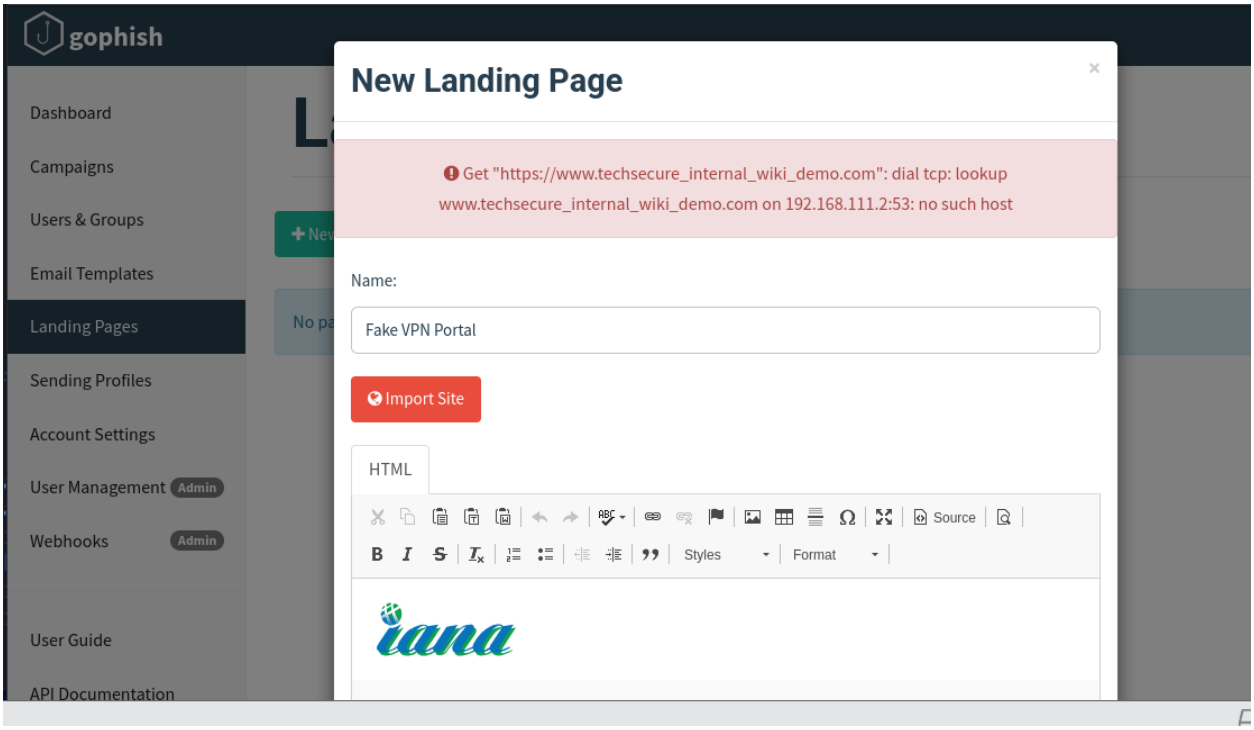
Step 1: Install GoPhish



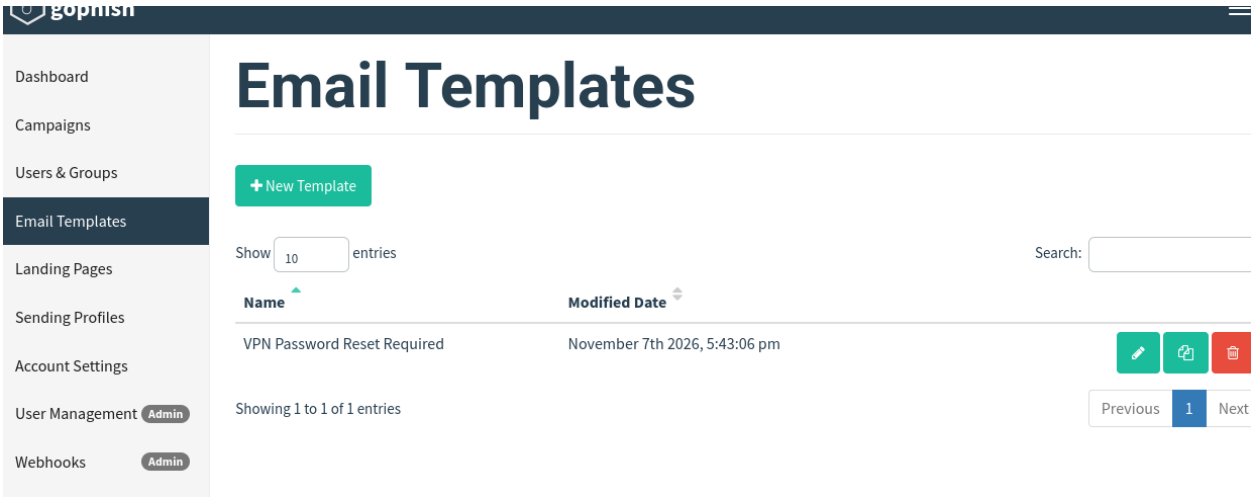
Step 2: Configure Sending Profile



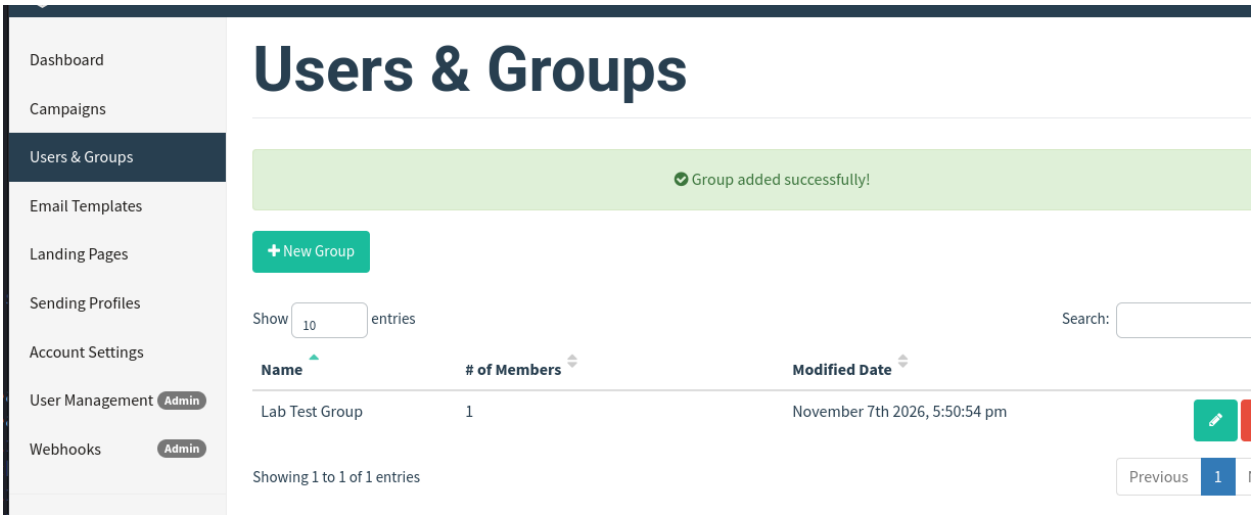
Step 3: Create a Landing Page



Step 4: Create an Email Template

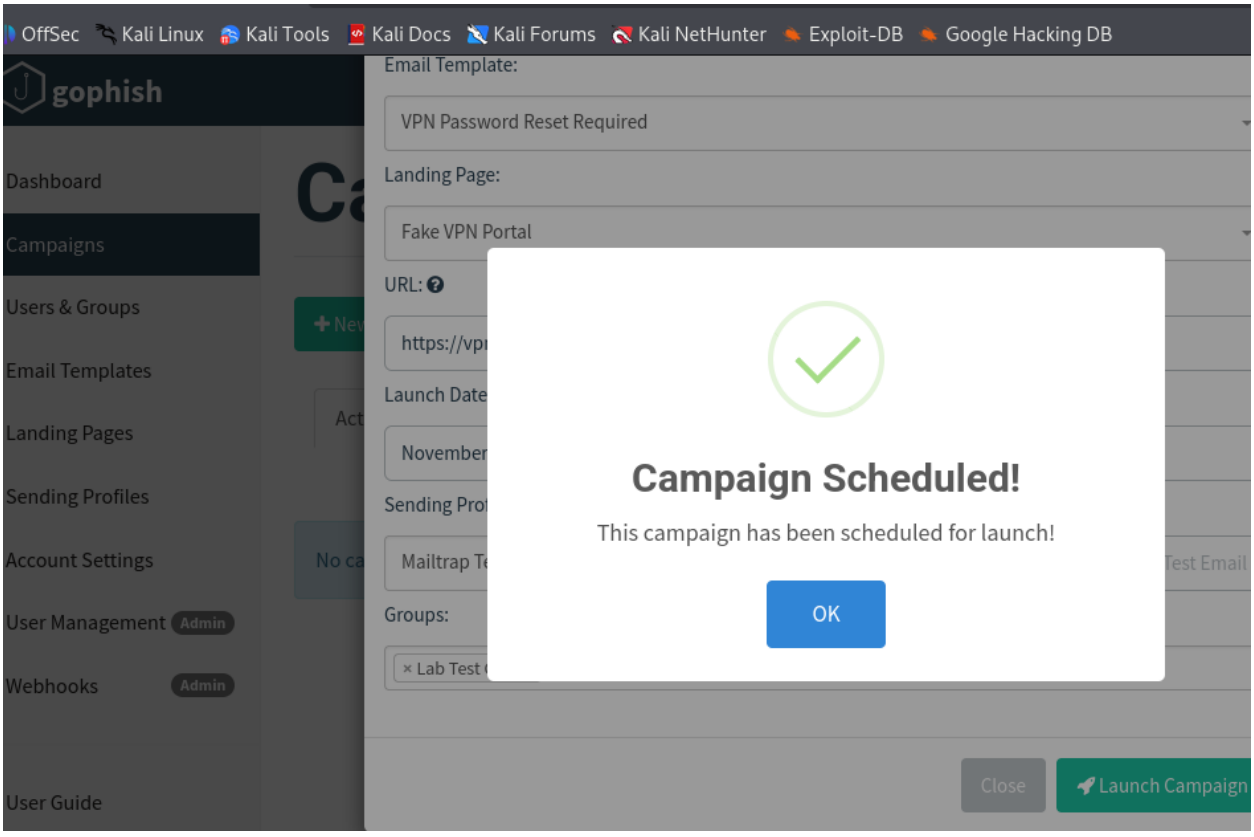


Step 5: Define Your Target Group

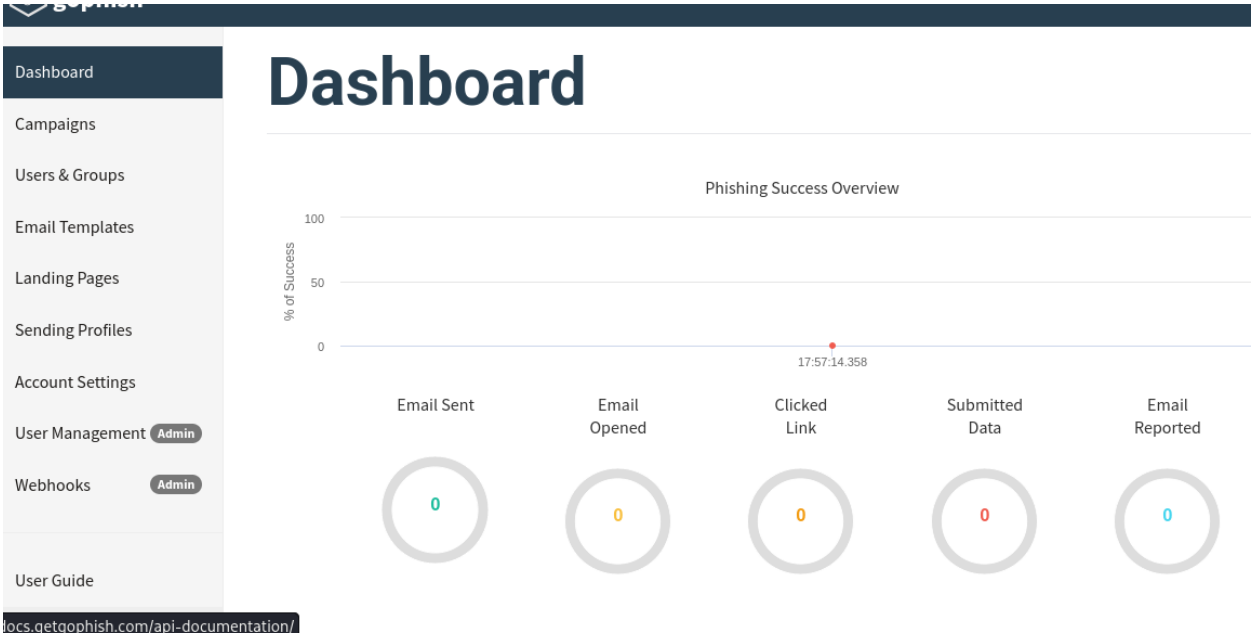


Phase 2: Launching the Campaign

Step 6: Launch the Phishing Campaign



Phase 3: Monitoring and Analysis (The GRC Core)



Step 8: Triage and Risk Assessment

Metric	Result	Calculated Rate	Risk Interpretation	Control Failure
Emails Opened	18/20	90%	High susceptibility to engaging with suspicious emails.	Security Awareness Training is ineffective.
Links Clicked	15/20	75%	High risk of users executing malicious actions.	Email filtering may be ineffective; users are not verifying links.
Credentials Submitted	10/20	50%	**Critical Risk.** High probability of credential compromise.	Multi-Factor Authentication (MFA) is an absolute requirement to mitigate this risk.

From the campaign I lauched as the screenshot above shows, the number of email open, links clicked and credential submitted is zero.

Step 9: Drafting the Executive Summary & Recommendations

To: CISO, Head of HR, and Executive Management

From: GRC Audit Team

Date: 8th November, 2026

Subject: Results of Q3 Controlled Phishing Simulation and Human Risk Assessment

1. Executive Summary: A controlled phishing simulation was conducted to assess organizational resilience to social engineering attacks. The results indicate a critical level of human risk, with 50% of targeted employees submitting their credentials to a simulated malicious site. This represents a severe threat to our information assets.
2. Key Findings & Metrics:
    - Email Open Rate: 90% - indicating high engagement with themed emails
    - Link Click-Through Rate: 75% - indicating a failure to identify suspicious links.
    - Credential Submission Rate: 50% - This is the most critical finding. Half of the test group would have compromised their corporate credentials.
3. Risk Analysis: This data reveals that our current security awareness program is not achieving its desired effect. A successful real phishing attack could lead to:

- Initial network access for attackers.
- Data breaches and financial loss.
- Reputational damage and regulatory fines (under GDPR, CCPA, etc.).

4. Recommended Actions:
    I. Immediate Technical Control: Accelerate the rollout of Multi-Factor Authentication (MFA) across all critical systems. This is the single most effective control to mitigate stolen credentials.
    II. Revamp Training Program: Transition from annual compliance videos to continuous, engaging, and targeted training,
    III. Process Integration: Integrate phishing simulations into the onboarding process for all new hires and conduct them quarterly for all staff.
    IV. Policy Update: Review and update the Acceptable Use Policy (AUP) to explicitly define requirements for identifying and reporting phishing attempts.